Chính sách mật khẩu và xác thực (phiên bản 2)

Phiên bản: 2.0 | Ngày hiệu lực: 01/01/2024 | Đơn vị ban hành: Khối Công nghệ thông tin (giả định)

1. Thông tin kiểm soát tài liệu

Hạng mục	Nội dung
Mã tài liệu	SYN-D08b
Đơn vị sở hữu	Khối Công nghệ thông tin (giả định)
Người phê duyệt	Giám đốc Công nghệ thông tin
Đối tượng áp dụng	Toàn bộ nhân sự và bên thứ ba được cấp tài khoản công ty
Phân loại	Nội bộ
Ghi chú	Tài liệu giả lập để kiểm thử, không phải chính sách VSF đã xác nhận

Phiên bản 2 của Chính sách mật khẩu và xác thực có hiệu lực từ ngày 01/01/2024 và đang được áp dụng. Phiên bản này thay thế hoàn toàn Chính sách mật khẩu và xác thực (phiên bản 1); khi có mâu thuẫn, nhân sự thực hiện theo phiên bản 2.

2. Mục đích, phạm vi và căn cứ

2.1 Mục đích

Chính sách này đặt ra yêu cầu đối với mật khẩu và việc xác thực người dùng trên các hệ thống của công ty nhằm giảm nguy cơ tài khoản bị đoán, bị đánh cắp hoặc bị lạm dụng. Phần lớn sự cố bảo mật bắt nguồn từ thông tin đăng nhập bị lộ, nên việc siết chặt yêu cầu về mật khẩu và xác thực là biện pháp hiệu quả nhất về chi phí để bảo vệ dữ liệu công ty.

Chính sách cũng làm rõ trách nhiệm của từng bên trong vòng đời tài khoản, từ lúc kích hoạt lần đầu, sử dụng hằng ngày, đổi mật khẩu, khôi phục cho đến khi thu hồi.

2.2 Phạm vi và đối tượng áp dụng

Chính sách áp dụng cho mọi tài khoản do công ty cấp, gồm tài khoản email, tài khoản đăng nhập máy tính, tài khoản VPN, tài khoản hệ thống nội bộ, tài khoản quản trị và tài khoản của nhà thầu được cấp quyền tạm thời. Chính sách áp dụng cho nhân viên chính thức, nhân viên thử việc, thực tập sinh và các bên thứ ba có tài khoản; không có nhóm nào được miễn.

2.3 Căn cứ và tài liệu liên quan

- Nội quy lao động: quy định về bảo mật thông tin và xử lý vi phạm.
- Chính sách phân loại dữ liệu: xác định mức độ nhạy cảm của dữ liệu mà tài khoản được truy cập.
- Quy trình báo cáo sự cố bảo mật: cách báo khi nghi ngờ tài khoản bị chiếm quyền.
- Hướng dẫn kích hoạt tài khoản và cài VPN: các bước kích hoạt tài khoản lần đầu và đặt mật khẩu mới.
- Chính sách làm việc từ xa: yêu cầu về VPN và tài khoản khi làm việc ngoài văn phòng.
- Sổ tay nhân viên: phần tóm tắt về an toàn thông tin cho nhân sự mới.

3. Định nghĩa và thuật ngữ

Thuật ngữ	Ý nghĩa
Mật khẩu	Chuỗi ký tự bí mật dùng để chứng minh người dùng là chủ tài khoản
Xác thực nhiều yếu tố (MFA)	Xác thực bằng từ hai yếu tố trở lên, ví dụ mật khẩu và mã xác nhận trên điện thoại
Mật khẩu tạm	Mật khẩu do hệ thống hoặc IT cấp khi mở tài khoản hoặc khôi phục
Khóa tài khoản	Trạng thái tạm thời ngăn đăng nhập sau nhiều lần nhập sai liên tiếp
Tài khoản đặc quyền	Tài khoản có quyền quản trị hoặc quyền thay đổi cấu hình hệ thống
Tài khoản dịch vụ	Tài khoản dùng cho ứng dụng hoặc tác vụ tự động, không gắn với một người
Lịch sử mật khẩu	Danh sách các mật khẩu gần nhất hệ thống ghi nhớ dạng băm để chặn dùng lại
Trình quản lý mật khẩu	Công cụ do công ty cho phép, lưu và sinh mật khẩu an toàn
Tấn công giả mạo	Chiêu lừa người dùng nhập mật khẩu hoặc mã xác nhận vào trang giả

4. Vai trò và trách nhiệm

Vai trò	Trách nhiệm chính	Ghi chú
Người dùng	Tạo mật khẩu đúng yêu cầu, bật MFA, không chia sẻ, đổi đúng hạn	Chịu trách nhiệm về tài khoản của mình
Quản lý trực tiếp	Nhắc nhở đội nhóm tuân thủ, xác nhận nhu cầu quyền	Không được giữ mật khẩu của nhân sự
IT Helpdesk	Cấp mật khẩu tạm, khôi phục tài khoản, đăng ký lại MFA	Xác minh danh tính trước khi thao tác
Khối Công nghệ thông tin	Cấu hình hệ thống áp dụng chính sách, duy trì tài liệu	Chủ sở hữu tài liệu
Trực SOC	Tiếp nhận báo cáo tài khoản bị chiếm quyền, hướng dẫn xử lý	Hoạt động 24/7
Chủ tài khoản dịch vụ	Bảo quản, đổi và bàn giao mật khẩu tài khoản dịch vụ	Được chỉ định bằng văn bản

5. Yêu cầu mật khẩu

Mật khẩu có tối thiểu 12 ký tự, gồm chữ hoa, chữ thường, chữ số và ký tự đặc biệt. Mật khẩu phải được đổi 90 ngày một lần và không được dùng lại 5 mật khẩu gần nhất.

5.1 Độ dài và độ phức tạp

Độ dài tối thiểu 12 ký tự là ngưỡng thấp nhất, không phải mức khuyến nghị. Mật khẩu phải có đủ bốn nhóm ký tự: chữ hoa, chữ thường, chữ số và ký tự đặc biệt như dấu chấm than, dấu gạch dưới hoặc dấu phần trăm. Hệ thống từ chối mật khẩu không đáp ứng đủ các điều kiện này và hiển thị điều kiện còn thiếu.

Nhân sự nên dùng cụm từ gồm nhiều từ ghép với chữ số và ký tự đặc biệt, dài hơn mức tối thiểu, vì mật khẩu dài khó bị dò hơn mật khẩu ngắn nhưng phức tạp. Không dùng từ có trong từ điển ở dạng đơn giản, tên đăng nhập, tên công ty, tên sản phẩm hoặc thông tin cá nhân như ngày sinh, số điện thoại, tên người thân.

5.2 Thời hạn đổi mật khẩu

Mật khẩu phải được đổi 90 ngày một lần. Hệ thống nhắc nhân sự đổi mật khẩu trước ngày hết hạn 7 ngày. Nếu quá hạn mà chưa đổi, tài khoản bị yêu cầu đổi mật khẩu ngay ở lần đăng nhập kế tiếp và không được truy cập hệ thống nào khác cho đến khi hoàn tất. Ngoài chu kỳ đổi định kỳ, nhân sự phải đổi ngay khi nghi ngờ mật khẩu bị lộ.

5.3 Lịch sử mật khẩu và không dùng lại

Mật khẩu mới không được trùng với 5 mật khẩu gần nhất của cùng tài khoản. Việc đổi một vài ký tự so với mật khẩu cũ, ví dụ chỉ thay đổi chữ số ở cuối, không được xem là mật khẩu mới thực chất và có thể bị hệ thống từ chối. Nhân sự không dùng chung mật khẩu giữa các tài khoản công ty khác nhau và không dùng mật khẩu công ty cho tài khoản cá nhân.

5.4 Mật khẩu tạm

Mật khẩu tạm do IT cấp chỉ dùng để đăng nhập lần đầu và phải được đổi trong vòng 24 giờ, phù hợp với Hướng dẫn kích hoạt tài khoản và cài VPN. Nhân sự không dùng lại mật khẩu tạm làm mật khẩu chính, không chuyển tiếp mật khẩu tạm qua tin nhắn hoặc email cho người khác.

5.5 Điều không được làm

- Không chia sẻ mật khẩu với đồng nghiệp, quản lý, IT hoặc bất kỳ ai, kể cả khi được đề nghị qua điện thoại hoặc tin nhắn. IT Helpdesk không bao giờ hỏi mật khẩu.
- Không ghi mật khẩu lên giấy dán ở bàn làm việc hoặc lưu trong tệp văn bản, bảng tính hoặc ghi chú không được bảo vệ.
- Không dùng mật khẩu công ty cho tài khoản cá nhân như mạng xã hội hoặc mua sắm trực tuyến.
- Không gõ mật khẩu vào liên kết nhận qua chat hoặc email; chỉ đăng nhập từ địa chỉ do công ty công bố.
- Không cho phép trình duyệt lưu mật khẩu công ty trên thiết bị không thuộc công ty.

6. Xác thực nhiều yếu tố

Xác thực nhiều yếu tố (MFA) là bắt buộc đối với mọi tài khoản công ty.

6.1 Phạm vi bắt buộc

Yêu cầu bắt buộc áp dụng cho toàn bộ tài khoản công ty, không phân biệt loại nhân sự hay cấp bậc: email, VPN, hệ thống nội bộ, kho mã nguồn, công cụ quản trị và tài khoản của nhà thầu. Tài khoản không bật MFA không được cấp quyền truy cập hệ thống nội bộ. Nhân sự mới bật MFA ngay khi kích hoạt tài khoản lần đầu, cùng lúc đặt mật khẩu mới.

6.2 Phương thức xác thực được chấp nhận

- Mã xác nhận sinh ra từ ứng dụng xác thực trên điện thoại (khuyến khích dùng).
- Khóa bảo mật vật lý do công ty cấp cho tài khoản đặc quyền.
- Mã xác nhận gửi qua tin nhắn chỉ dùng làm phương án dự phòng.

6.3 Bảo vệ yếu tố xác thực

- Không chia sẻ mã xác nhận với bất kỳ ai; mã là bí mật như mật khẩu.
- Chỉ chấp nhận yêu cầu xác nhận khi chính mình vừa đăng nhập; nếu nhận yêu cầu xác nhận mà mình không thực hiện, từ chối và báo Trực SOC.
- Đặt khóa màn hình cho điện thoại dùng làm yếu tố xác thực.
- Khi đổi hoặc mất điện thoại đã đăng ký MFA, thông báo ngay cho IT Helpdesk để đăng ký lại thiết bị; IT xác minh danh tính trước khi thay đổi.

Nếu điện thoại bị mất kèm nguy cơ lộ tài khoản, đây là sự cố bảo mật và nhân sự báo Trực SOC theo Quy trình báo cáo sự cố bảo mật, không chỉ liên hệ IT Helpdesk.

7. Khóa tài khoản và khôi phục

7.1 Khóa tài khoản

Tài khoản bị khóa tạm thời 15 phút sau 5 lần nhập sai mật khẩu liên tiếp. Sau thời gian khóa, người dùng có thể đăng nhập lại. Nếu tài khoản bị khóa lặp lại nhiều lần trong ngày, hệ thống ghi nhận cảnh báo cho Khối Công nghệ thông tin để kiểm tra dấu hiệu dò mật khẩu. Việc khóa nhằm bảo vệ tài khoản và không phải hình thức kỷ luật.

7.2 Khôi phục mật khẩu và MFA

1. Người dùng liên hệ IT Helpdesk qua email it-helpdesk@vsf-demo.example hoặc cổng IT và nêu tên tài khoản.
2. IT Helpdesk xác minh danh tính bằng thông tin đã đăng ký, không xác minh bằng mật khẩu cũ.
3. IT Helpdesk cấp mật khẩu tạm qua kênh đã đăng ký của người dùng.
4. Người dùng đăng nhập, đổi mật khẩu trong vòng 24 giờ và xác nhận lại MFA.
5. Nếu nghi ngờ tài khoản bị chiếm quyền, người dùng báo Trực SOC theo Quy trình báo cáo sự cố bảo mật trước khi thực hiện các bước trên.

8. Lưu trữ và bảo vệ mật khẩu

Mật khẩu được hệ thống lưu ở dạng băm, không lưu dạng văn bản thuần. Nhân viên IT không thể xem mật khẩu của người dùng. Nhân sự cần ghi nhớ nhiều mật khẩu nên dùng trình quản lý mật khẩu do công ty cho phép thay vì ghi ra giấy, và bảo vệ kho mật khẩu bằng một mật khẩu chính đủ mạnh cùng MFA.

8.1 Tài khoản đặc quyền

Tài khoản đặc quyền tuân thủ mọi yêu cầu như tài khoản thông thường, không có ngoại lệ, và phải dùng riêng cho công việc quản trị. Quản trị viên không dùng tài khoản đặc quyền để đọc email hoặc duyệt web hằng ngày. Việc cấp quyền đặc quyền cần được quản lý trực tiếp phê duyệt theo quy trình xin cấp quyền hệ thống.

8.2 Tài khoản dịch vụ và tài khoản nhà thầu

Mỗi tài khoản dịch vụ phải có chủ tài khoản được chỉ định bằng văn bản. Khi chủ tài khoản nghỉ việc hoặc chuyển vị trí, mật khẩu của tài khoản dịch vụ được đổi và quyền được bàn giao. Tài khoản nhà thầu có thời hạn sử dụng rõ ràng, bị thu hồi khi hết hợp đồng và cũng phải bật MFA.

9. Vi phạm và xử lý

Vi phạm chính sách được xử lý theo Nội quy lao động. Việc chia sẻ mật khẩu hoặc mã xác nhận, để người khác dùng tài khoản của mình hoặc tắt MFA là vi phạm nghiêm trọng. Khi việc vi phạm gây lộ dữ liệu, công ty có thể xem xét trách nhiệm cá nhân theo mức độ thiệt hại.

Hành vi	Mức độ	Cách xử lý
Không đổi mật khẩu đúng hạn	Nhẹ	Nhắc nhở và yêu cầu đổi ngay
Dùng lại mật khẩu cũ bằng cách sửa ít ký tự	Nhẹ	Hệ thống từ chối, yêu cầu tạo mật khẩu mới
Ghi mật khẩu ở nơi dễ thấy	Trung bình	Nhắc nhở bằng văn bản
Tắt hoặc đi vòng MFA	Nghiêm trọng	Xử lý theo Nội quy lao động
Chia sẻ mật khẩu hoặc mã xác nhận	Nghiêm trọng	Xử lý theo Nội quy lao động
Cố ý dò mật khẩu tài khoản của người khác	Nghiêm trọng	Xử lý kỷ luật và báo cáo sự cố

Nhân sự có thể gửi phản hồi về việc bị xử lý hoặc về yêu cầu của chính sách tới IT Helpdesk hoặc HR Onboarding; Khối Công nghệ thông tin ghi nhận để xem xét trong kỳ rà soát tài liệu.

10. Ví dụ minh họa

Ví dụ 1. Nhân sự đặt mật khẩu gồm 11 ký tự có đủ chữ hoa, chữ thường, chữ số và ký tự đặc biệt. Hệ thống vẫn từ chối vì mật khẩu chưa đạt tối thiểu 12 ký tự. Nhân sự thêm ký tự để đạt yêu cầu.

Ví dụ 2. Nhân sự đang dùng mật khẩu, đến kỳ đổi định kỳ và muốn quay lại mật khẩu đã dùng cách đây ba lần đổi. Hệ thống từ chối vì mật khẩu đó nằm trong 5 mật khẩu gần nhất; nhân sự phải chọn mật khẩu khác.

Ví dụ 3. Nhân sự nhận được thông báo xác nhận đăng nhập trên điện thoại trong khi mình không đăng nhập. Nhân sự từ chối yêu cầu, đổi mật khẩu theo hướng dẫn và báo Trực SOC vì đây có thể là dấu hiệu người khác đã biết mật khẩu.

Ví dụ 4. Nhân sự làm mất điện thoại đã đăng ký MFA. Nhân sự thông báo ngay cho IT Helpdesk để đăng ký lại thiết bị mới sau khi xác minh danh tính, đồng thời báo Trực SOC nếu có nguy cơ lộ tài khoản.

11. Câu hỏi thường gặp

Hỏi: Mật khẩu cần tối thiểu bao nhiêu ký tự và gồm những gì? Đáp: Tối thiểu 12 ký tự, gồm chữ hoa, chữ thường, chữ số và ký tự đặc biệt.

Hỏi: Bao lâu phải đổi mật khẩu một lần? Đáp: 90 ngày một lần; hệ thống nhắc trước ngày hết hạn 7 ngày.

Hỏi: Tôi có được dùng lại mật khẩu cũ không? Đáp: Không được dùng lại 5 mật khẩu gần nhất.

Hỏi: MFA có bắt buộc không? Đáp: Có. MFA là bắt buộc đối với mọi tài khoản công ty.

Hỏi: Nhập sai mật khẩu nhiều lần thì sao? Đáp: Tài khoản bị khóa tạm thời 15 phút sau 5 lần nhập sai liên tiếp.

Hỏi: Tôi quên mật khẩu thì liên hệ ai? Đáp: IT Helpdesk qua it-helpdesk@vsf-demo.example; IT xác minh danh tính rồi cấp mật khẩu tạm và người dùng phải đổi trong vòng 24 giờ.

Hỏi: IT có bao giờ hỏi mật khẩu của tôi không? Đáp: Không. IT Helpdesk không hỏi mật khẩu và không cần biết mật khẩu để hỗ trợ.

Hỏi: Tôi có thể ghi mật khẩu vào sổ tay cá nhân không? Đáp: Không nên. Hãy dùng trình quản lý mật khẩu do công ty cho phép.

Hỏi: Điện thoại đăng ký MFA của tôi bị mất thì làm gì? Đáp: Báo IT Helpdesk để đăng ký lại và báo Trực SOC nếu nghi ngờ lộ tài khoản.

Hỏi: Thực tập sinh có phải bật MFA không? Đáp: Có, chính sách không miễn nhóm nào.

Hỏi: Nhà thầu có phải tuân thủ không? Đáp: Có, tài khoản nhà thầu cũng phải bật MFA và có thời hạn sử dụng rõ ràng.

12. Phụ lục

12.1 Phụ lục A. Danh sách kiểm tra cho người dùng

- Mật khẩu có ít nhất 12 ký tự, đủ chữ hoa, chữ thường, chữ số và ký tự đặc biệt.
- Mật khẩu không trùng 5 mật khẩu gần nhất.
- Đã bật MFA cho mọi tài khoản công ty.

- Không dùng mật khẩu công ty cho tài khoản cá nhân.
- Không ghi mật khẩu ở nơi dễ thấy; dùng trình quản lý mật khẩu được phép.
- Biết cách báo Trực SOC khi nghi ngờ tài khoản bị chiếm quyền.

12.2 Phụ lục B. Mẫu email yêu cầu khôi phục tài khoản

Tiêu đề: Đề nghị khôi phục mật khẩu - [Tên tài khoản]. Nội dung: Kính gửi IT Helpdesk, tôi không đăng nhập được tài khoản [tên tài khoản] do quên mật khẩu. Tôi đề nghị xác minh và hỗ trợ cấp mật khẩu tạm qua kênh đã đăng ký. Tôi hiểu rằng phải đổi mật khẩu trong vòng 24 giờ.

12.3 Phụ lục C. Bảng tra cứu nhanh

Nội dung	Yêu cầu	Người hỗ trợ
Độ dài mật khẩu	Tối thiểu 12 ký tự	IT Helpdesk
Chu kỳ đổi	90 ngày một lần	IT Helpdesk
Không dùng lại	5 mật khẩu gần nhất	IT Helpdesk
MFA	Bắt buộc với mọi tài khoản	IT Helpdesk
Khóa tài khoản	15 phút sau 5 lần sai liên tiếp	IT Helpdesk
Nghi ngờ chiếm quyền	Báo ngay Trực SOC	Trực SOC

13. Lịch sử sửa đổi

Phiên bản	Ngày	Nội dung thay đổi
1.0	2022-01-01	Ban hành lần đầu chính sách mật khẩu và xác thực
2.0	2024-01-01	Tăng độ dài tối thiểu của mật khẩu, rút ngắn chu kỳ đổi mật khẩu, bổ sung quy định không dùng lại mật khẩu gần nhất và chuyển xác thực nhiều yếu tố từ khuyến nghị thành bắt buộc